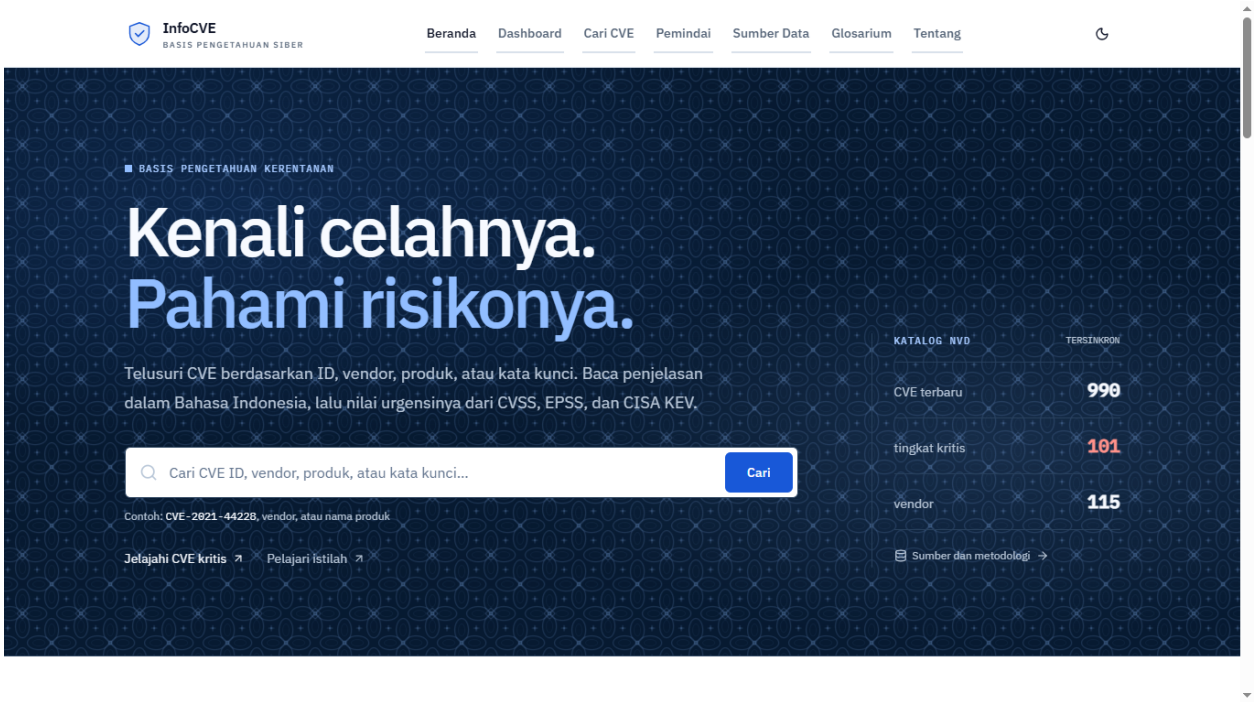
KARTIKA CYBER HACKATHON 2026 / DEFENSIVE SHIELD

InfoCVE

Platform Edukasi dan Triase Kerentanan Siber

Proposal teknis untuk membantu tim memahami risiko CVE, menilai dependency npm, dan menelusuri dasar setiap rekomendasi.

AGENDA	**Kartika Cyber Hackathon 2026**
KATEGORI	**Penangkalan (Defensive Shield)**
REPOSITORI	**github.com/Fachri-analys/infocve**
APLIKASI	**https://infocve.vercel.app**



Tampilan InfoCVE pada deployment web. Data katalog berasal dari sumber kerentanan yang dicantumkan di dalam aplikasi.

Status bukti dan data pada dokumen ini diperiksa 3 November 2026.

Ringkasan Eksekutif

InfoCVE adalah platform web berbahasa Indonesia untuk mencari CVE, memahami tingkat risikonya, dan memeriksa apakah dependency npm yang digunakan proyek cocok dengan versi terdampak. Aplikasi menggabungkan data NVD dengan sinyal CISA KEV dan FIRST EPSS. Pemindai dependency membandingkan inventory package dengan advisori OSV.dev serta melakukan pemeriksaan silang GitHub Security Advisories bila tersedia.

Tujuan InfoCVE adalah membuat informasi kerentanan lebih mudah ditindaklanjuti. Pengguna dapat menelusuri sumber bukti, melihat deskripsi Indonesia jika proses terjemahan tersedia, membaca informasi mitigasi yang memiliki referensi, membandingkan hasil pemindaian ulang, dan mengunduh laporan PDF atau JSON. InfoCVE adalah purwarupa pendukung triase; hasilnya tidak menggantikan pemeriksaan keamanan menyeluruh atau keputusan pemilik sistem.

Masalah yang Ditangani

Data kerentanan tersedia dalam banyak format dan sering menggunakan istilah teknis berbahasa Inggris. Tim pengembang dan pengelola sistem perlu menghubungkan identitas paket, versi yang terpasang, rentang terdampak, tingkat keparahan, eksploitasi yang diketahui, dan saran perbaikan. Tanpa konteks itu, daftar CVE sulit dipakai untuk menyusun urutan tindak lanjut.

Tujuan Produk

- Menyediakan pencarian dan penjelasan CVE yang dapat dibaca dalam Bahasa Indonesia.
- Membantu pengguna mengurutkan pekerjaan dengan sinyal CVSS, EPSS, CISA KEV, dan bukti PoC yang tersedia.
- Memindai dependency npm secara statis dan menghubungkan setiap temuan ke advisori serta rentang versi.
- Menyimpan riwayat scan dan mencatat kapan status perbaikan belum dapat diverifikasi.

Pengguna yang Dituju

InfoCVE ditujukan untuk pelajar keamanan siber, pengembang aplikasi, administrator sistem, dan tim keamanan yang membutuhkan ringkasan kerentanan serta pemeriksaan awal dependency. Untuk konteks pertahanan dan instansi, platform dapat menjadi bahan edukasi dan triase awal. Penggunaan operasional pada jaringan atau sistem milik instansi memerlukan evaluasi, persetujuan, dan integrasi tersendiri.

Fitur yang Sudah Tersedia

Fitur	Cara kerja dan batasan
Katalog dan pencarian CVE	Pencarian berdasarkan ID, vendor, produk, kata kunci, dan filter. Di Vercel, katalog persisten tersimpan di Neon dan diisi melalui NVD API 2.0.
Prioritas InfoCVE	Label P1-P4 dan NA memakai aturan internal yang menggabungkan CVSS, EPSS, CISA KEV, dan indikator eksploit. Label ini bukan standar resmi pengganti CVSS.
Pemindai npm	Membaca package.json dan package-lock.json secara statis, termasuk dependency transitif. Aplikasi tidak memasang paket atau menjalankan kode dari unggahan.
Pencocokan advisori	Identitas ekosistem dan paket, PURL, versi terpasang, dan rentang terdampak dibandingkan dengan data OSV.dev. GitHub Security Advisories dipakai untuk pemeriksaan silang ketika tersedia.
Terjemahan dan mitigasi	Deskripsi asli tetap disimpan. Terjemahan diproses di background jika provider dikonfigurasi. Rekomendasi ditautkan ke sumber; informasi yang tidak tersedia atau bertentangan perlu ditinjau.
Verifikasi dan laporan	Pemindaian ulang membandingkan temuan sebelumnya dan terbaru dengan status Resolved, Still Detected, atau Unverified. Hasil aktual dapat diekspor ke PDF dan JSON.

Alur Pemindaian Dependency

- Pengguna mengunggah package.json dan package-lock.json dari revisi proyek yang sama.
- InfoCVE membaca lockfile dan membentuk inventory versi dependency langsung serta transitif tanpa menjalankan isi berkas.
- Scanner meminta advisori package ke OSV.dev, lalu memeriksa GHSA yang berhubungan jika tersedia.
- Pencocokan mengevaluasi ekosistem npm, identitas package, versi, dan batas rentang terdampak. Konflik sumber atau data kurang lengkap diberi status review.
- Laporan menyajikan temuan, bukti sumber, rekomendasi, keterbatasan, dan status pemindaian. Pengguna dapat memindai ulang setelah perubahan dependency.

Makna Status Hasil

Completed berarti cakupan pemindaian selesai tanpa temuan yang memerlukan peringatan tambahan. Completed with Warnings berarti pemindaian selesai tetapi sebagian temuan atau data perlu perhatian. Incomplete berarti sebagian inventory atau sumber belum diperiksa penuh. Failed berarti scanner tidak memperoleh hasil yang dapat dipakai. Hasil kosong hanya berarti tidak ada temuan pada cakupan dan sumber yang berhasil diperiksa; hasil itu bukan bukti bahwa aplikasi sepenuhnya aman.

Arsitektur dan Pengelolaan Data

InfoCVE menggunakan Next.js App Router dan TypeScript. Adapter terpisah menangani sumber eksternal, lalu normalisasi mengubah respons provider ke model CVE internal. Pada deployment Vercel, Neon menyimpan katalog CVE, cursor sinkronisasi, antrean terjemahan, dan riwayat scanner. Mode lokal menggunakan SQLite bawaan Node.js.

Bagian	Tanggung jawab
NVD API 2.0	Sumber utama record CVE dan deskripsi asli.
CISA KEV dan FIRST EPSS	Sinyal tambahan untuk menunjukkan eksploitasi yang tercatat dan estimasi probabilitas eksploitasi.
OSV.dev dan GitHub Advisories	Sumber advisori untuk pencocokan dependency npm; setiap temuan membawa referensi yang dapat dibuka.
Neon dan proses sinkronisasi	Menyimpan data produksi secara persisten. Cron melanjutkan backfill NVD 120 hari melalui cursor.
Antarmuka InfoCVE	Menyediakan pencarian, detail CVE, dashboard, pemindai, riwayat, glosarium, dan ekspor laporan.

Kontrol Keamanan

- File package.json dan package-lock.json dibaca sebagai data; proses pemindaian tidak menjalankan kode aplikasi atau lifecycle script.
- Endpoint sinkronisasi dilindungi secret admin atau secret Cron. Kunci provider disimpan di environment server.
- Riwayat scan dilindungi token akses acak. File mentah yang diunggah tidak disimpan; hasil terstruktur dan riwayat scan disimpan sesuai konfigurasi database.
- Laporan memuat sumber, waktu scan, cakupan, status verifikasi, dan keterbatasan agar keputusan dapat ditelusuri.

Pembaruan Katalog

Backfill awal mencakup publikasi NVD selama maksimal 120 hari. Satu eksekusi mengambil maksimal 1.000 entri NVD dan memiliki timeout request 45 detik di dalam batas function Vercel 60 detik. Cursor diteruskan oleh Cron harian sampai jendela selesai, sehingga status incomplete selama proses berjalan adalah wajar. CVE inti disimpan sebelum proses enrichment. Tanggal TIMESTAMPTZ dari Neon dikirim ke NVD dalam format ISO 8601.

Bukti Implementasi dan Pengujian

Pemeriksaan deployment pada 3 November 2026 menunjukkan katalog Neon tersedia dengan 990 CVE unik. Pada saat yang sama, halaman beranda, dashboard, dan pencarian merespons HTTP 200 serta memuat ID CVE. Angka katalog merupakan snapshot dan berubah ketika sinkronisasi berlanjut.

Pemeriksaan	Hasil aktual
TypeScript	npm run typecheck - lulus.
Lint	npm run lint - lulus.
Unit dan regresi	npm test - 165 lulus, 4 dilewati.
Integrasi Neon	npm run test:neon - 4 lulus pada database uji yang terpisah dari database aplikasi.
Build	npm run build - selesai. Akses Neon dari lingkungan build lokal tidak tersedia; katalog produksi diverifikasi melalui health endpoint dan halaman live.

Batasan yang Perlu Dipahami

- Scanner saat ini mendukung package.json dan package-lock.json untuk ekosistem npm. Ekosistem Python, Java, Go, dan C/C++ belum didukung.
- Analisis bergantung pada kelengkapan dan ketersediaan NVD, OSV.dev, GitHub Security Advisories, dan provider terjemahan. Gangguan sumber harus tampil sebagai incomplete atau failed, bukan hasil aman.
- Prioritas P1-P4 merupakan metode triase InfoCVE. Metode ini bukan skor resmi dan tidak menggantikan penilaian risiko organisasi.
- InfoCVE tidak menerapkan patch secara otomatis, tidak menganalisis perilaku runtime, dan tidak menyatakan aplikasi bebas kerentanan.
- Backfill NVD berjalan per halaman pada Cron harian; pengisian seluruh jendela 120 hari dapat memerlukan beberapa eksekusi.

Rencana Pengembangan

Tahap	Rencana
Penguatan akurasi	Membangun golden dataset yang ditinjau, lalu mengukur precision, recall, false positive, false negative, dan F1 sebelum menetapkan klaim akurasi.
Perluasan ekosistem	Menambah parser dan pencocokan untuk ekosistem di luar npm setelah model bukti dan pengujian tersedia.
Kesiapan deployment	Mengevaluasi mode mirror data, integrasi pipeline CI, retensi, kontrol akses, dan operasi jaringan terbatas bersama pemilik sistem.

Sumber dan Atribusi

InfoCVE menautkan sumber pada detail CVE, temuan scanner, dan laporan. Ringkasan atau terjemahan tidak mengubah kepemilikan atas data sumber. Produk ini menggunakan NVD API dan tidak didukung atau disertifikasi oleh NVD. Penggunaan record CVE tetap mengikuti CVE Program Terms of Use, termasuk kewajiban copyright designation dan lisensi MITRE; ketentuan publisher lain tetap berlaku.

NVD API dan ketentuan penggunaan https://nvd.nist.gov/developers/terms-of-use

CISA Known Exploited Vulnerabilities https://www.cisa.gov/known-exploited-vulnerabilities-catalog

FIRST EPSS https://www.first.org/epss/

OSV.dev data dan sumber https://google.github.io/osv.dev/data/

GitHub Advisory Database https://github.com/advisories

CVE Program Terms of Use https://www.cve.org/Legal/TermsOfUse

Repositori InfoCVE https://github.com/Fachri-analys/infocve